Lab-04: Prioritise Vulnerabilities by Business Risk

Course: Cyber Security Awareness Workshop

Course code: C506

Time: 35 minutes

Alignment: LO1

Tool: [Ethical Hacking Simulator](https://alfredang.github.io/ethnicalhacking/)

Scenario

An SME has limited maintenance time and must decide which exposures to address first.

Safety and authorisation boundary

- Use only the named training tool and the mock files in this folder.
- Do not enter real passwords, personal data, payment details or confidential information.
- Do not test any other website, network, account or organisation.
- Stop immediately if the target, data or behaviour differs from the written scope.
- Prefer reversible actions and preserve synthetic evidence.

Mock data

- `mock-vulnerability-register.csv`
- `mock-asset-context.csv`

Detailed procedure

1. Review each vulnerability together with asset owner, internet exposure, data sensitivity and operational criticality.

2. Use the simulator only in its authorised training environment to observe how attack preconditions change risk.

3. Calculate risk as likelihood × impact, then adjust the score for active exploitation, reachability and control strength.

4. Rank the vulnerabilities and state why severity alone does not determine business priority.

5. Select a treatment: patch, isolate, disable, add a compensating control, accept temporarily or retire the asset.

6. Set an owner, due date and verification method for the top three actions.

Completion standard

- Ranked risk register
- Top-three rationale
- Treatment decisions
- Owners and due dates
- Verification plan

Reflection

What evidence would make you reverse your decision, and who would need to know?